Support de cours

Firewall

Classes: L3-ASI

Enseignant : AGOUTOCO-POKO Caleb Benaja
WhatsApp (00228) 92227441/ 99990031

Année universitaire : 2025/2026

Prérequis :

- Notions de réseaux (OSI, TCP/IP)
- Sécurité informatique de base
- Administration système et réseau

Module 3 : Règles et Stratégies de Filtrage des Firewalls

Module 3 : Règles et Stratégies de Filtrage des Firewalls

Dans ce module, nous allons approfondir les stratégies de filtrage et la gestion des règles d'un pare-feu. Nous aborderons les **listes de contrôle d'accès (ACLs)**, le **filtrage par adresse IP et ports**, le **filtrage applicatif (couche 7)**, l'**inspection approfondie des paquets (DPI)** et la **gestion des logs**.

1. Notion de Règles de Pare-feu (ACLs, Policy-Based Filtering)

Définition des ACLs (Access Control Lists)

Les **ACLs** définissent les règles de filtrage appliquées aux paquets traversant le firewall. Elles peuvent être **stateless** (simple filtrage) ou **stateful** (avec suivi des connexions).

Exemple de règle ACL sous Cisco :

```
access-list 101 permit tcp any host 192.168.1.10 eq 80
access-list 101 deny ip any any
```

Cette règle **autorise** le trafic TCP vers l'IP **192.168.1.10** sur le port **80** et **bloque tout le reste**.

Filtrage Basé sur des Politiques (Policy-Based Filtering)

Certains firewalls appliquent des **politiques de filtrage dynamiques**, prenant en compte :

- L'utilisateur (authentification avant accès à certaines ressources).
- L'heure (accès autorisé aux sites web professionnels en journée).
- L'emplacement (accès différent selon le réseau source).

2. Filtrage Basé sur les Adresses IP et Ports

Filtrage par Adresse IP

Un firewall peut **autoriser ou bloquer** des adresses IP spécifiques.

Exemple sous iptables :

```
sudo iptables -A INPUT -s 192.168.1.100 -j DROP
```

Bloque tout le trafic venant de **192.168.1.100**.

Filtrage par Port

Les firewalls filtrent le trafic selon les **ports TCP/UDP** (exemple : bloquer le port 23 - Telnet).

Exemple sous iptables :

```
sudo iptables -A INPUT -p tcp --dport 23 -j DROP
```

Bloque les connexions Telnet.

3. Filtrage Basé sur les Applications (Layer 7 Filtering)

Pourquoi un filtrage applicatif ?

Un simple filtrage IP/port ne suffit pas pour détecter les **protocoles cachés** (ex. : VPN, proxy contournant les restrictions).

Exemple : Bloquer YouTube avec un Firewall Next-Generation

- Certains firewalls NGFW peuvent bloquer **l'application YouTube**, même si elle utilise des **ports dynamiques**.
- Ex. : Bloquer **Facebook** avec **pfSense** :

```
acl facebook dstdomain .facebook.com
http_access deny facebook
```

Technologies utilisées :

- DPI (Deep Packet Inspection)
- Filtrage HTTPS (SSL Inspection)
- Filtrage par catégories (Web Filtering)

4. Inspection des Paquets (Deep Packet Inspection - DPI)

Définition

Le **DPI** analyse **le contenu** des paquets (pas seulement les adresses IP et ports). Il permet :

1- Détection des virus/malwares.

2- Filtrage des contenus interdits (torrent, réseaux sociaux).

3- Identification des applications utilisées.

Exemple : DPI avec un NGFW (Cisco, FortiGate)

- **Détecte et bloque** les protocoles interdits (ex. : Tor, VPN).
- **Analyse le trafic chiffré (SSL/TLS Inspection)**.

Outils de DPI Open Source :

- **Suricata** (IDS/IPS)
- **Snort** (Détection d'intrusion)

5. Gestion des Logs et Surveillance

Pourquoi surveiller un firewall ?

Détection des attaques en temps réel.

Analyse des tentatives de connexion suspectes.

Optimisation des règles pour améliorer la sécurité.

Exemple : Visualisation des logs sous Linux (iptables logs)

```
sudo iptables -A INPUT -p tcp --dport 22 -j LOG --log-prefix "SSH_ATTEMPT: "
```

Enregistre les tentatives de connexion SSH dans /var/log/syslog.

Outils de surveillance des logs :

- SIEM (Splunk, ELK Stack, Graylog)
- Firewall Logs Analyzer (pfSense, FortiAnalyzer)

Conclusion

Une bonne stratégie de filtrage combine plusieurs niveaux :

ACLs pour le filtrage **basique**.

Filtrage par IP/Port pour le contrôle **statique**.

Filtrage applicatif pour le contrôle **avancé**.

DPI pour la **détection des menaces cachées**.

Logs et surveillance pour la **réactivité face aux attaques**.

TP 1 : Sécurisation d'un Réseau d'Entreprise

Une entreprise souhaite sécuriser son réseau en appliquant des règles strictes sur son pare-feu. Voici les exigences :

1. Autoriser uniquement les connexions SSH (port 22) et HTTP/HTTPS (ports 80 et 443).
2. Bloquer tout accès provenant de l'adresse IP **203.0.113.50**.
3. Interdire l'accès aux sites de réseaux sociaux (Facebook, Instagram, TikTok).
4. Surveiller les tentatives de connexion SSH et les enregistrer dans les logs.

TP 2 : Mise en Place d'une DMZ Sécurisée

Une entreprise héberge un site web et un serveur FTP. Elle veut :

1. Placer ces serveurs dans une **DMZ**.
2. Autoriser uniquement le trafic web (HTTP/HTTPS) et FTP vers la DMZ.
3. Empêcher les machines de la DMZ d'accéder au réseau interne.

TP 3 : Protection Contre les Attaques DoS/DDoS

Un serveur web est victime d'attaques DoS par des requêtes répétées. L'entreprise veut :

1. Limiter le nombre de connexions simultanées sur le port 80.
2. Bloquer les IP effectuant plus de 10 requêtes en 5 secondes.